



电子科技大学
University of Electronic Science and Technology of China

计算机系统与网络安全技术

Technology of Computer System and Network Security

牛伟纳

计算机科学与工程学院（网络空间安全学院）

2025年3月7日星期五





第6章：恶意软件

- 恶意软件的类型
- 高级持续性威胁
- 传播-感染内容-病毒
- 传播-漏洞利用-蠕虫
- 传播-社会工程-垃圾电子邮件、木马
- 载荷-系统损坏
- 载荷-代理攻击-zombie, bots
- 载荷-信息窃取-键盘记录器、网络钓鱼、间谍软件
- 载荷-隐藏-后门、rootkits
- 对抗手段

恶意软件

恶意软件的定义

- 一种被（往往是秘密地）植入系统中，以损害受害者数据、应用程序或操作系统的机密性、完整性或可用性，抑或对用户实施骚扰或妨碍的程序。
——NIST SP 800-83

恶意软件

恶意软件的相关术语

名 称	描 述
高级持续性威胁 (APT)	指向商业性和政治性目标、使用多种入侵技术和恶意软件，并在很长一段时间内发起持续有效的攻击的网络犯罪，其元凶往往是由国家支持的组织
广告软件 (adware)	集成在软件中的广告程序。它能够产生弹出式广告或将浏览器重定向到某个商业网站
攻击工具包 (attack kit)	一套通过使用各种传播和载荷机制自动生成新恶意软件的工具
Auto-rooter	用于远程入侵到新的机器上的恶意攻击工具
后门 (陷门)	能够绕过正常安全检查的任何机制，它可以允许未经授权访问某些功能
下载器 (downloader)	在被攻击的机器上安装其他内容的程序。通常下载器是包含在恶意代码中的，该恶意代码首先被安装在被感染系统中，而后下载大量的恶意软件
路过式下载 (drive-by-download)	一种利用受感染网站的攻击方式。当该网站被访问时，被植入其中的恶意代码可以利用浏览器中的漏洞攻击访问者所在的系统
漏洞攻击程序 (exploit)	针对某个或多个漏洞进行攻击的代码
洪泛攻击程序 (DoS)	通过向联网的计算机系统发送大量数据包而实现拒绝服务攻击的程序
键盘记录器 (keylogger)	捕获受控系统中键盘输入的程序

恶意软件

恶意软件的相关术语

名 称	描 述
逻辑炸弹	被入侵者插到正常软件中的程序。当预定义的条件满足时，逻辑炸弹被触发，开始执行非授权的操作；其他时间处于休眠状态
宏病毒	一种使用宏或脚本语言编写的病毒，通常被植入一个文档中，当该文档被浏览或编辑时被触发和运行，然后复制自身至其他的文档
移动代码	能够不加修改地移植到不同类型的系统平台上并按照完全相同的语义执行的软件（如脚本、宏或其他可移植的指令）
rootkit	攻击者成功入侵计算机系统并获得 root 访问权限之后使用的一套攻击工具
垃圾邮件程序	发送大量垃圾邮件的程序
间谍软件（spyware）	通过监听键盘输入、显示器数据或网络流量，或通过搜寻系统中的文件获取敏感信息，并将收集到的信息发送给另一台计算机的软件
特洛伊木马	一种计算机程序，看上去具有有用的功能，但还具有隐蔽的、潜在的恶意功能，这些恶意功能可以用来避开安全机制的检查，有时是利用调用被感染系统的合法授权来实现的
病毒	在执行时设法将自己复制到其他可执行代码中的恶意软件。如果复制成功，就称这个可执行代码被感染了。当被感染的可执行代码运行时，病毒也同时被执行
蠕虫	能够独立执行并且可以将自己完整的可执行版本传播到网络中其他主机上的计算机程序，通常通过攻击目标系统中软件的漏洞或使用捕获的授权凭证来实现
僵尸机（zombie、bot）	在被感染的计算机中运行，激活后向其他计算机发动攻击的程序

恶意软件的类型

恶意软件的分类

- 分为两大类：
 - 基于其向目标传播或感染的方式进行分类
 - 在到达目标后，基于其工作方式或有效载荷进行分类
- 其他分类方式：
 - 依据恶意软件是否依附于宿主程序
 - 考虑该恶意软件是否可以复制

恶意软件的类型

恶意软件的分类

传播机制包括:

- 对现有可执行程序的感染或由病毒翻译并随后传播至其他系统的内容
- 利用软件漏洞（无论是从本地发起或借助蠕虫、路过式下载等方式从网络发起)来允许恶意软件自我复制
- 借助社会工程学方法说服用户绕过安全机制来安装木马或响应网络钓鱼



恶意软件一旦到达目标系统，其将表现出的有效载荷的行为可能包括:

- 污染系统或数据文件
- 窃取服务使系统成为僵尸网络中的一个僵尸代理
- 窃取系统信息，特别是登录口令和通过键盘记录器或间谍软件获取的隐私信息
- 隐蔽恶意软件的存在以防止其被系统检测和锁定

恶意软件的类型

Android恶意软件类型

- SMS-Sending: send/register users to premium numbers
- Spyware: collect sensitive/private information and upload to remote servers
- Destructive Trojans: modify content on the devices
- SMS-Sending: send/register users to premium
- Mobile botnets: receive command from remote C&C servers
- Ransomware: steal information and ask for money to get back

恶意软件的类型

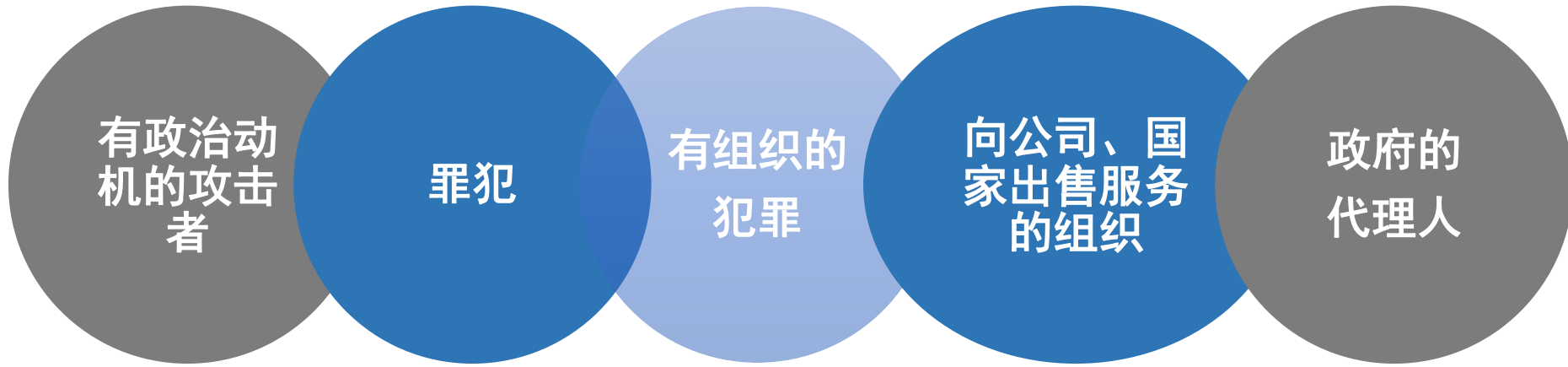
攻击工具包

- 最初，恶意软件是软件编写者为炫耀技术而开发和部署的
 - 在20世纪90年代早期，病毒工具开发包的出现改变了这种情况，而后在21世纪初期出现了更多通用的攻击包，这些攻击包在极大程度上助长了恶意软件的开发和部署
- 工具包通常被称为“犯罪软件”
 - 其包含了多种传播机制和有效载荷模块，即使新手菜鸟也可以进行组合、选择和部署
 - 所生成的恶意软件变种的绝对数量仍然会给对抗它们的防御系统造成相当大的麻烦
- 常见的攻击工具包实例：
 - Zeus
 - 钓鱼

恶意软件的类型

攻击源

- 近几十年来，恶意软件开发发生了一些变化，攻击者由个人的、以炫耀技术为目的的变化为更加有组织和危害性更大的攻击源。比如：



- 在恶意软件数量上升的背后，是制作动机的改变，这种改变实际上催生了出售攻击包的地下经济，获取受害主机的控制权和盗窃信息

恶意软件的类型

Android恶意软件如何植入手机

❑ Malware installation is driven by three main social engineering-based techniques

-Repackaging

-Update attack

-Drive-by download

❑ These techniques can be used in combination

❑ They require the user intervention

恶意软件的类型

重打包

- ❑ This is a very common technique among malware authors
- ❑ Malicious payload is piggybacked into popular apps
- ❑ Users are then lured to download these infected apps
- ❑ To hide malicious payload authors use class names that look legitimate:
 - AnserverBot uses `com.sec.android.provider.drm`
 - DroidKungFu uses `com.google.ssearch` and `com.google.update`
- ❑ The malware family jSMShider has used a private key of the AOSP to sign its apps!
- ❑ Locate and download popular apps
- ❑ Disassemble apps and enclose malicious payloads
- ❑ Re-assemble the apps and upload on official and/or alternative markets
- ❑ Apps used include paid apps, popular game apps, utility apps, security tools, and porn-related apps
- ❑ When the code of an app is changed so is its cryptographic signature
- ❑ However, a vulnerability was discovered where the app cryptographic signature is not changed even if the code of the app is modified

<http://bluebox.com/corporate-blog/bluebox-uncovers-android-master-key/>

恶意软件的类型

更新攻击

- ❑ Repackaging techniques put the whole malicious code in the host apps
- ❑ This might expose them to the risk of being detected
- ❑ Update attacks lower this risk by inserting only an update component as payload
- ❑ This component can be still inserted in already packaged popular app
- ❑ BaseBridge malware requests the user that a new version of the app is available
 - The new version contains the malicious payload
 - Note that the updated version is hidden within the main app!
- ❑ DroidKungFuUpdate is similar to BaseBridge
 - However the malicious payload is downloaded remotely
- ❑ The whole update of an app requires user intervention to be successful
- ❑ AnserverBot and Plankton update only part of the host app not the entire app
 - In this way, they do not require the user permission
- ❑ Plankton fetches a jar file from a remote server
- ❑ AnserverBot retrieves a public(encrypted) entry from a blog containing the malicious payload

恶意软件的类型

drive-by download

- ❑ This technique is similar to the one used in PC through the browsers
- ❑ Lure the user to click a link to download some cool stuff!
- ❑ However, Android malware does not require the browser for performing this attack
- ❑ Jifake uses a similar technique of GGTracker
- ❑ Instead of a link in an advert, it uses a QR code
- ❑ The code downloaded is a repackaged ICQ client
- ❑ Once installed it will send SMS to premium numbers
- ❑ GGTracker uses an in-app advertisement
- ❑ When the user clicks a special link on an adv it will redirect to a malicious website
- ❑ The website claims to analyse the phone battery for increasing its performance
- ❑ Instead a malicious payload is downloaded that will register the user to a premium-rate service without the user's consent
- ❑ Spitmo and ZitMo are two variants of the SpyEye and Zeus PC banking malware
- ❑ While the user is using an infected PC for her banking, a link will prompt to download a smartphone app to better protect online banking activities.
- ❑ The app is actually a malware that will collect banking credentials from mTAN and SMS
- ❑ In Europe, these two malware have stolen US \$40M

恶意软件的类型

其它攻击方式

- ❑ Apps that claim themselves as spyware-no need to hide!
- ❑ Apps that masquerade as legitimate apps but then perform malicious actions
- ❑ Apps that provide the functionality claimed plus perform malicious actions
- ❑ Apps that rely on root-exploits to gain root privileges

高级持续性威胁

高级持续性威胁（APT）

- 具有充足资源，对选定目标(通常是商业或政治) 应用大量入侵技术和恶意软件的持续性应用程序
- 通常来自国家支持的组织，有些攻击也可能来自犯罪企业
- 与其他类型攻击不同的是，APT精心地对目标进行选择，具有持续性，通常是隐秘的，入侵者在相当的时期内都要致力于攻击
- 值得关注的攻击包括Aurora、RSA、APT1和Stuxnet

高级持续性威胁

APT特征

高级

- 攻击者使用多种入侵技术和恶意软件，如果有需要还会开发定制的恶意软件
- 其中单一的组件在技术上也许不先进，但是每个组件都是针对目标精心选择的

持续性

- 攻击者用很长时间确定针对攻击目标的攻击应用可以最大化攻击成功的概率
- 攻击手段的种类是逐渐递增的，通常是非常隐秘的，直到目标被攻陷

威胁

- 针对选定目标的威胁来自有组织、有能力和有良好经济支持的攻击者，他们试图攻陷这些目标
- 在攻击过程中，攻击者的积极参与极大地提升了自动攻击工具的威胁等级，也增加了成功攻击的可能性

高级持续性威胁

APT攻击

目的

- 包括窃取知识产权或安全和基础设施相关数据，也包括基础设施的物理损坏

攻击技术

- 社会工程
- 钓鱼邮件
- 选取目标组织中的人员可能会访问的网站植入下载驱动

意图

- 试图利用老练的恶意软件，通过多种传播机制和有效载荷感染目标
- 一旦获取了目标组织的系统初始权限，攻击者会利用更多的攻击工具来维持和提升他们的访问权

高级持续性威胁

APT攻击统计

攻击组织

- 2024 年上半年，朝鲜 APT 团伙 Kimsuky 在攻击频率上位居榜首，重点攻击中国财务人员的银狐团伙势头正猛，依然稳坐第二名，另外一个朝鲜组织 Lazarus 活动频率显著下降，相反俄罗斯 APT28 组织活动明显增多，两者并列第三。较 2023 年而言，巴基斯坦 Transparent Tribe 组织活动有所增加，现排名第四。此外，新兴黑产团伙 amdc6766 也开始崭露头角，对软件供应链行业构成巨大威胁。

目标

- 2024 年上半年我国继续成为 APT 攻击的首要目标国，俄罗斯和美国并列第二，印度和韩国地区的排名有所上升，升至第三位。与此同时，乌克兰和以色列因各自持续的战争状态，目前排名第四。从整体分布来看，APT 活动依旧集中在亚太、中东和欧美三大地区，这表明地缘政治的影响在网络空间中仍然非常显著。

威胁

- APT 组织依旧采用木马后门、钓鱼攻击和漏洞利用作为主要攻击手段。不过，相较上半年而言，供应链攻击和社会工程学活动明显增多。表 1 详细列出了 2024 年上半年 APT 组织最频繁利用的漏洞，以及它们所针对的厂商和软件产品。

高级持续性威胁

厂商（漏洞数）	针对系统、组件或服务	漏洞号
Microsoft（5）	365_apps, Office, Outlook	CVE-2023-23397
	Windows、Windows Server	CVE-2024-21412
		CVE-2022-38028
		CVE-2024-21338
	Office	CVE_2017_11882
Ivanti（2）	Connect_secure, Policy_secure, Neurons_for_zero-trust_access	CVE-2024-21893
	Connect_secure, Policy_secure	CVE-2023-46805
Rarlab（1）	Winrar	CVE-2023-38831
PHP, Fedoraproject（1）	php, fedora	CVE-2024-4577

厂商（漏洞数）	针对系统、组件或服务	漏洞号
Oracle（1）	Weblogic_server	CVE-2017-3506
Cisco（1）	Adaptive_security_appliance_software, Firepower_threat_defense	CVE-2024-20353
Paloaltonetworks（1）	Pan-os	CVE-2024-3400
Connectwise（1）	Screenconnect	CVE-2024-1709
Igniterealtime（1）	Openfire	CVE-2023-32315
Aiohttp, Fedoraproject（1）	Aiohttp, Fedora	CVE-2024-23334

表 1 2024 年上半年 APT 组织最常用漏洞利用列表

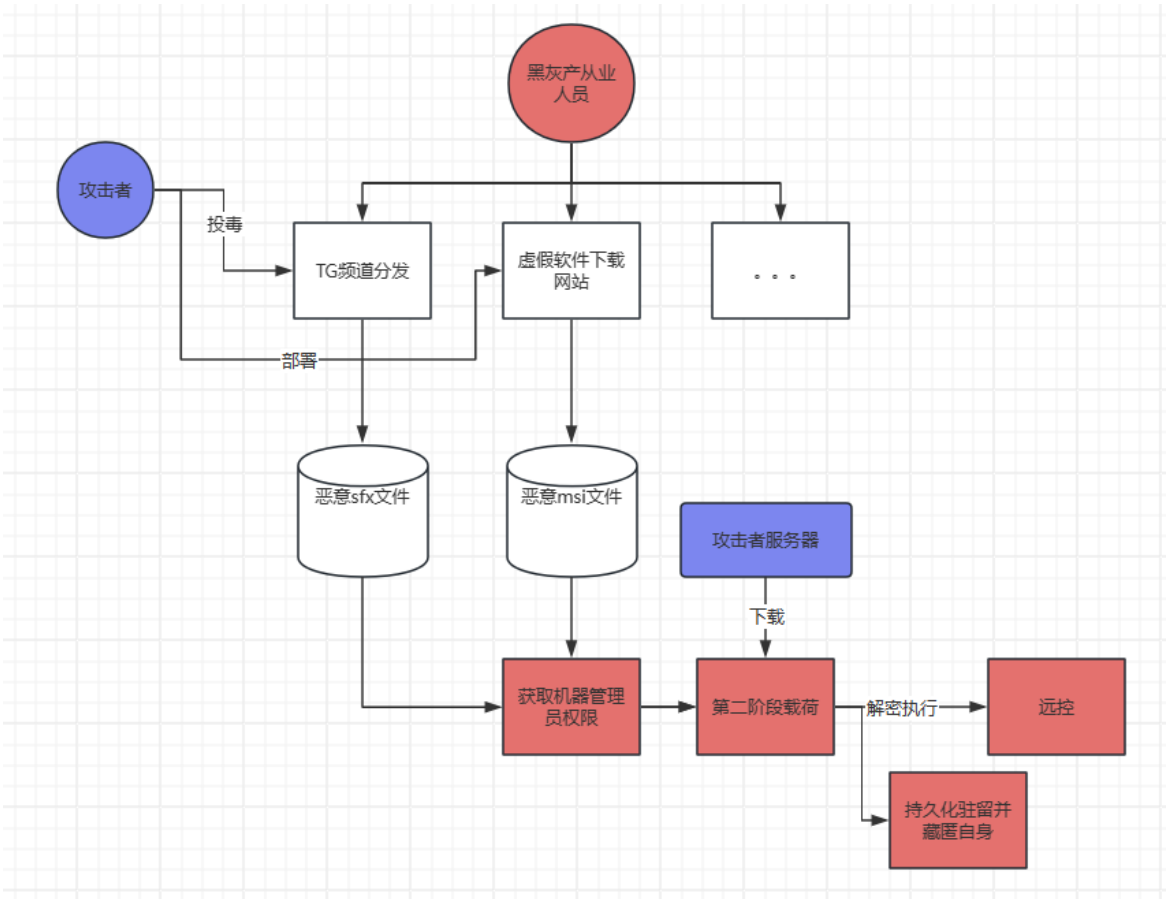
高级持续性威胁

APT攻击案例

银狐黑吃黑：利用伪造 MSI 安装包攻击黑产从业者

事件画像	
事件名称	银狐利用伪造的MSI安装包针对黑产从业者发起攻击
技术特点	1. 使用MSI安装程序进行载荷投递实现免杀； 2. MSI文件安装后利用“白加黑”方式加载恶意载荷； 3. 利用动态下载的shellcode获取最终C2地址。
攻击目标	黑产从业人员
平台	Windows
传播方式	虚假应用程序下载站，Telegram频道分发
攻击地区	中国
攻击目的	远控，窃密
攻击工具	Gh0st

攻击者通过从黑产从业人员的行为进行分析，在黑产从业人员的多个接触渠道进行投毒钓鱼，并且制作免杀马来绕过杀毒软件查杀，受害者选择点击安装后将在本地释放相关恶意组件，并从托管服务器中获取shellcode解密执行，最终实现远控。



高级持续性威胁

APT攻击案例

来自Timitator组织RUST特马的攻击



Timitator(战术模仿者) 组织自2022年到2023年针对我国的能源、高校、科研机构及军工等行业进行攻击，主要采取鱼叉、nday等方式进行打点。

本次捕获到多个Timitator钓鱼样本，分析后发现：在2024-03-28之后上传的样本中，没有使用CobaltStrike作为远控工具，而是使用一个由RUST语言编写的远控工具，简称为RUST特马。

描述	详细信息
名称	1.exe
文件大小	17185768 bytes
文件类型	EXE
文件功能	Loader
编译时间	/
开发平台及语言	/
是否加壳	否
VT首次上传时间	2024-04-12 07:56:11 UTC
md5	4a2e2fe59c21cbefbbad3bb8d2852a44
Sha256	aac2cbd4cb119dec6c9a8c58f86b8bdd83d27fdaed85149bb2572599de9e32c0

传播-感染内容-病毒

病毒

- 感染程序的一种软件
 - 修改它们以包括病毒的副本
 - 复制并继续感染其他内容
 - 容易通过网络环境传播
- 病毒附在可执行程序上时，它可以做该程序被允许做的任何事情
 - 在主机程序运行时秘密执行
- 具体根据不同的操作系统和硬件而异
 - 利用他们的细节和弱点

传播-感染内容-病毒

病毒的组成元素

感染机制

- 病毒传播和进行自我复制的方法
- 也被称为感染向量

触发条件

- 激活或交付病毒有效载荷的事件或条件
- 有时也被称为逻辑炸弹

有效载荷

- 指病毒除传播之外的活动
- 包括破坏活动，也包括无破坏但值得注意的良性活动

传播-感染内容-病毒

病毒周期

潜伏阶段

- 病毒处于休眠状态
- 最后会被某个事件激活
- 并非所有的病毒都有这个阶段



传播阶段

- 病毒将自身的拷贝插入其他程序或硬盘上某个与系统相关的区域
- 该拷贝也许会与原始版本不完全一样，病毒通过变异来逃避检测
- 每个被感染程序包含病毒拷贝



执行阶段

- 执行病毒功能
- 功能可能是无害或有害的



触发阶段

- 病毒被激活以执行其预先设定的功能
- 病毒进入触发阶段由多种系统事件引起，包含病毒自身复制的次数

传播-感染内容-病毒

宏病毒和脚本病毒

- NISTIR 7298将宏病毒定义为：
 - 一种附加到文档并使用文档应用程序的宏编程功能来执行和传播的病毒
- 宏病毒会感染用于支持各种用户文档类型中的活动内容的脚本代码
- 威胁性的原因有很多：
 - 宏病毒有独立的平台
 - 宏病毒感染的是文档而不是可执行部分的代码
 - 宏病毒的传播很容易
 - 宏病毒感染的是用户文档而不是系统程序，所以传统文件系统的访问控制在防止其扩散方面的作用有限，因为用户需要修改它们
 - 相比于传统的可执行病毒，宏病毒的制造或修改更加简单

传播-感染内容-病毒

病毒的分类

```
macro Document_Open
  disable Macro menu and some macro security features
  if called from a user document
    copy macro code into Normal template file
  else
    copy macro code into user document being opened
  end if
  if registry key "Melissa" not present
    if Outlook is email client
      for first 50 addresses in address book
        send email to that address
        with currently infected document attached
      end for
    end if
    create registry key "Melissa"
  end if
  if minute in hour equals day of month
    insert text into document being opened
  end if
end macro
```

传播-感染内容-病毒

病毒的分类——按目标分类

感染引导扇区病毒

感染主引导记录或引导记录，并在从包含病毒的磁盘引导系统时传播

感染可执行文件病毒

感染操作系统或shell认为可执行的文件

宏病毒

使用由应用程序解释的宏或脚本代码感染文件

多元复合型病毒

通过多种方式感染文件

传播-感染内容-病毒

病毒的分类——按隐藏方式分类

加密型病毒

先通过部分病毒代码生成一个随机密钥，然后用密钥加密其余部分

隐蔽型病毒

躲避反病毒软件的检测，将病毒整体进行隐蔽，一般通过代码的多态、压缩、或rootkit技术实现隐藏

多态病毒

一种在自我复制时生成功能相同但位排列方式完全不同的拷贝的病毒

变形病毒

一种在每次迭代中发生变异并完全重写自身的病毒，它可能改变行为和外观

传播-感染内容-蠕虫

蠕虫

- 是一种主动寻找并感染其他机器的程序，而每台被感染机器又转而成为自动攻击其他机器的跳板
- 利用客户端或服务程序中的软件漏洞
- 利用网络连接在系统间传播
- 也能通过共享媒介（如 USB设备或者CD、DVD数据光盘)进行传播
- 电子邮件蠕虫通过附带的文档或即时消息通信中的宏或脚本代码传播
- 一旦被激活，蠕虫就可以再次复制并传播
- 除了传播之外，蠕虫通常还会附带其他的一些有效载荷
- 第一个著名的蠕虫程序是20世纪80年代早期在Xerox Palo Alto实验室中实现

传播-感染内容-蠕虫

蠕虫的复制方法

电子邮件或即时工具

- 通过邮件将自己的拷贝发送到其他系统中去
- 自身当作即时通信服务的附件进行发送

文件共享

- 蠕虫可以在如USB设备等可插拔媒介上创建自己的拷贝

远程执行能力

- 蠕虫有在其他系统中执行自己的拷贝的能力

远程文件访问或传输能力

- 蠕虫利用远程文件访问或者传输服务向其他系统复制自身拷贝

远程登录能力

- 蠕虫以一个用户的身份登录到远程系统，然后使用命令将自己复制到将要被执行的另一个系统中

传播-感染内容-蠕虫

发现目标

- 扫描(或指纹采集)
 - 传播阶段的首要功能
 - 寻找其他系统进行感染

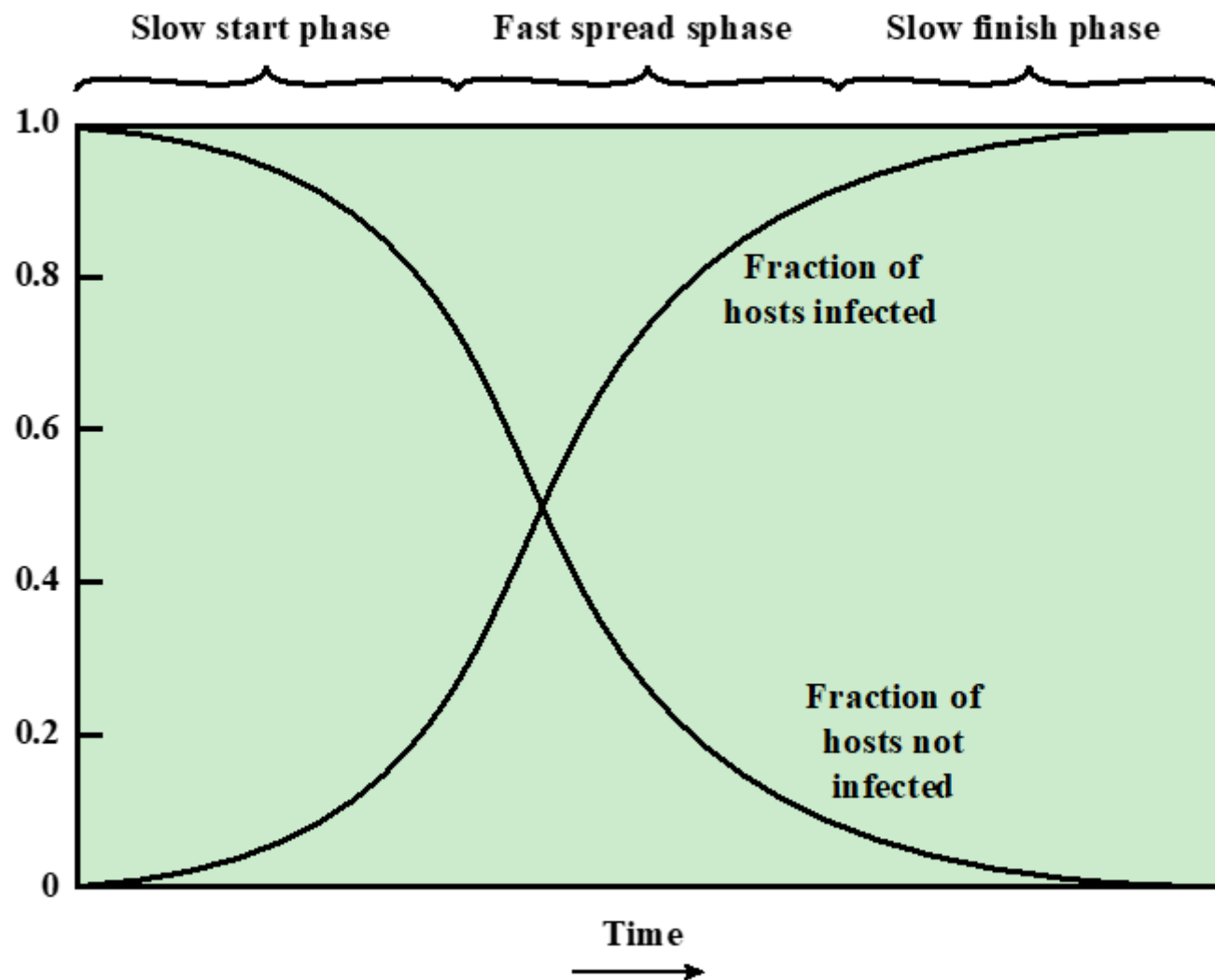
传播-感染内容-蠕虫

发现目标

- 随机式探索
 - 每一台被感染的主机使用不同的种子来探测IP地址空间的随机地址
 - 该技术会产生大量的网络流量，可能导致在实际攻击开展前，操作便会被中断
- 黑名单
 - 攻击者首先为潜在的易感染机器列出一个大名单
 - 一旦名单编辑完成，攻击者即开始感染名单中的机器
 - 每个被感染的机器会被分配名单中的一部分进行扫描
 - 这种策略会使得扫描时间非常短，因此检测感染的发生是非常困难的
- 拓扑式探索
 - 此方法利用被感染机器中包含的信息来寻找和扫描更多的主机
- 本地子网
 - 如果防火墙后的一台主机可以被感染，则该主机会在其所在的本地网络中寻找目标
 - 利用子网地址结构,被感染的主机可以寻找到其他本应受到防火墙保护的主机

传播-感染内容-蠕虫

蠕虫传播模型



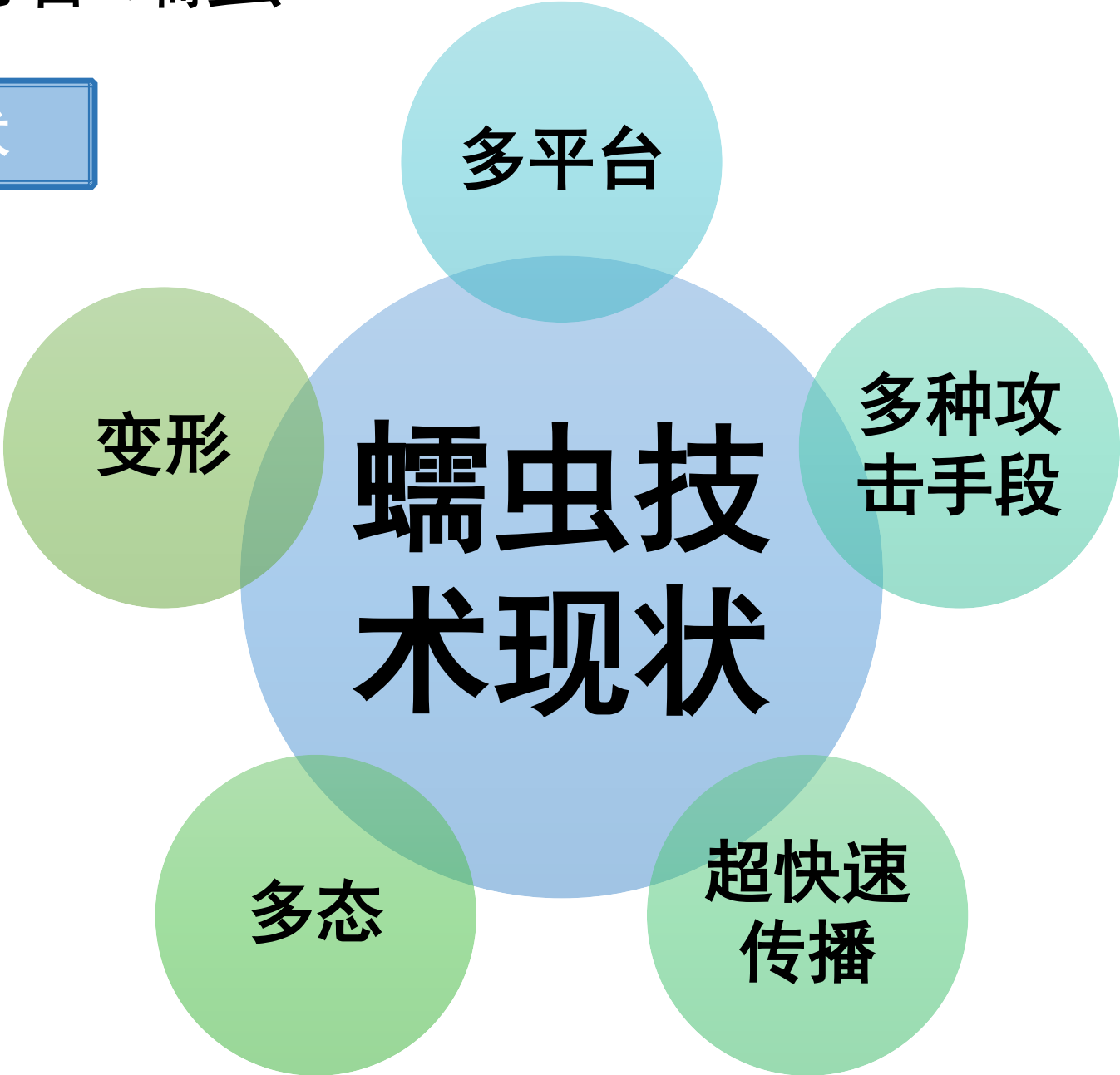
传播-感染内容-蠕虫

Morris 蠕虫

- 最早被人熟知的蠕虫
- 1998年被Robert Morris编写并发布到Internet上
- 为了在UNIX系统中传播而设计的
 - 试图破解本地口令文件，利用破解的口令和对应用户ID登录远程主机
 - 利用UNIX系统finger协议的漏洞，这个漏洞会报告远程用户的位置
 - 利用负责收发邮件的远程进程的调试选项中的一个陷门
- 任何一个成功让Morris蠕虫病毒能和操作系统命令解释器进行通信
 - 发送给解释器一个引导程序来复制蠕虫

传播-感染内容-蠕虫

蠕虫技术



传播-感染内容-蠕虫

移动代码

- NIST SP 800-28将移动代码定义为：
 - 不加修改就能够在不同系统平台上运行并且能够实现相同功能的程序
- 从远程系统传输到本地系统，然后在本地系统上执行
- 通常充当病毒、蠕虫或特洛伊木马的载体
- 移动代码能够利用漏洞实现某些功能

传播-感染内容-蠕虫

移动代码

- 常用的移动代码载体类型主要有：
 - Java applet
 - ActiveX
 - JavaScript
 - VBScript
- 使移动代码能够在本地系统进行恶意操作的最常见方式有：
 - 跨站点脚本
 - 交互式 and 动态的Web站点
 - 电子邮件附件
 - 从不可信网站下载程序或者下载不可信软件等

传播-感染内容-蠕虫

手机蠕虫

- 2004年，Cabir蠕虫首次被发现
- 然后是2005年的Lasco和CommWarrior
- 通过蓝牙无线连接或彩信进行传染
- 目标是智能手机
- 这些恶意程序可以使手机完全瘫痪，删除手机数据，或者向收取额外费用的号码发送信息
- CommWarrior蠕虫利用蓝牙技术像接受区域内的其他手机传播，它也以彩信的方式向手机通讯录中的号码发送自己的拷贝，而且会自动回复收到的短信和彩信

传播-感染内容-蠕虫

路过式下载

利用应用程序中的缺陷(bug)来安装恶意软件。使得当用户浏览一个受攻击者控制的Web页面时，该页面包含的代码会攻击该浏览器的缺陷并在用户不知情或未允许的情况下向系统安装恶意软件

在多数情况下，这类恶意软件不像蠕虫那样传播

等待那些无防备的用户浏览恶意的 Web页面来传播

传播-感染内容-蠕虫

恶意广告

通过Web站点部署恶意软件的技术，该技术不会真正损害Web站点

攻击者在他们目标网站付钱植入包含有恶意代码的广告

利用这些恶意植入代码,攻击者通过向访问者展示广告来令其感染

这些恶意代码是动态生成的，这同样可以减少被侦测到的机会，或者只感染特殊的系统

近年来，恶意广告发展迅速，因为它们很容易被放置在期望的网站上，而且几乎没有问题，也很难追踪

攻击者在预料到他们的受害者可能会浏览目标网站后仅仅将这些恶意广告放置几小时，以此来大幅度降低恶意广告的可见度

传播-感染内容-蠕虫

点击劫持

- 也称为用户界面(UI)伪装攻击
- 使用类似的技术，键盘输入也可以被劫持
 - 通过精心制作的可定义模板、iframe标签和文本框等页面元素的组合，用户会被误导而以为他们在为电子邮件或银行账户输入口令，而实际上他们将口令输入到了攻击者控制的一个无形的框架内
- 攻击者收集被感染用户点击信息的攻击
 - 攻击者可以强迫用户做一系列的事情，从调整计算机的设置到在用户不知情的情况下让用户访问可能含有恶意代码的网站
 - 利用Adobe Flash和JavaScript，攻击者甚至可能在一个合法按钮的上面或者下面部署一个按钮，并将其制作成难以被用户察觉的样子
 - 这种攻击的典型例子是利用多重透明或模糊的页面层次来欺骗用户在试图点击最上层页面时，却实际上点击了另一个按钮或链接到另一个页面
 - 攻击者实施点击劫持的意图是将一个页面链接至属于其他应用、域名的页面

点击劫持示例

Towards Discovering and Understanding Task Hijacking in Android

CHUANGANG REN, YULONG ZHANG, HUI XUE, TAO WEI, PENG LIU

PENN STATE UNIVERSITY, FIREEYE INC.

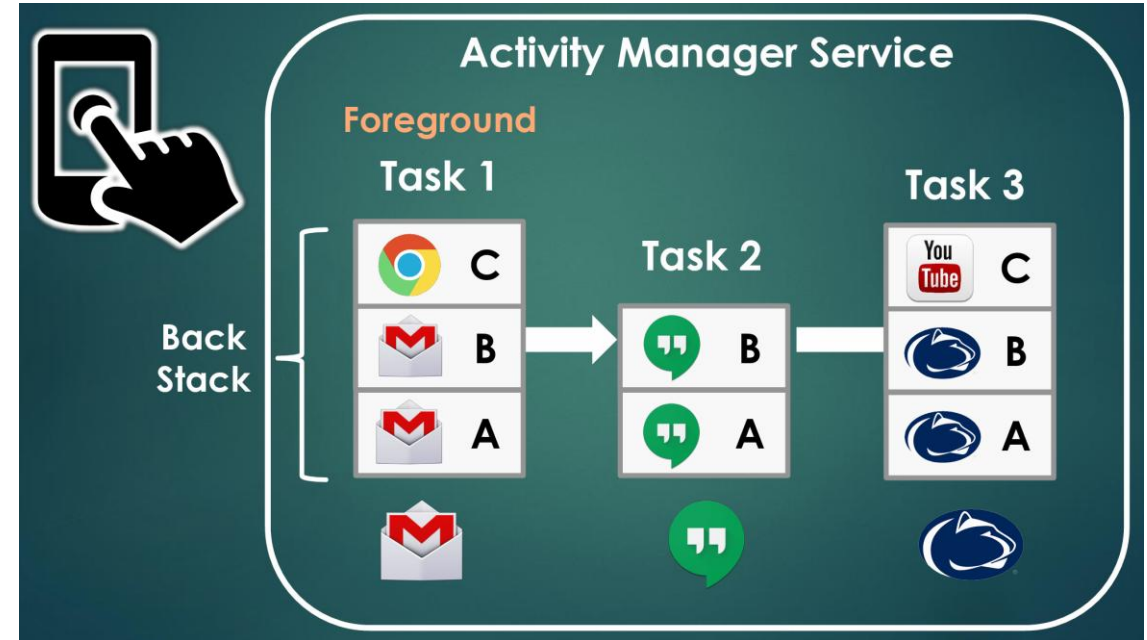
点击劫持示例

Android Multi-tasking

- ❑ In PC world, multitasking means multiple processes are running at the same period of time.
- ❑ In Android, multitasking is a different concept:

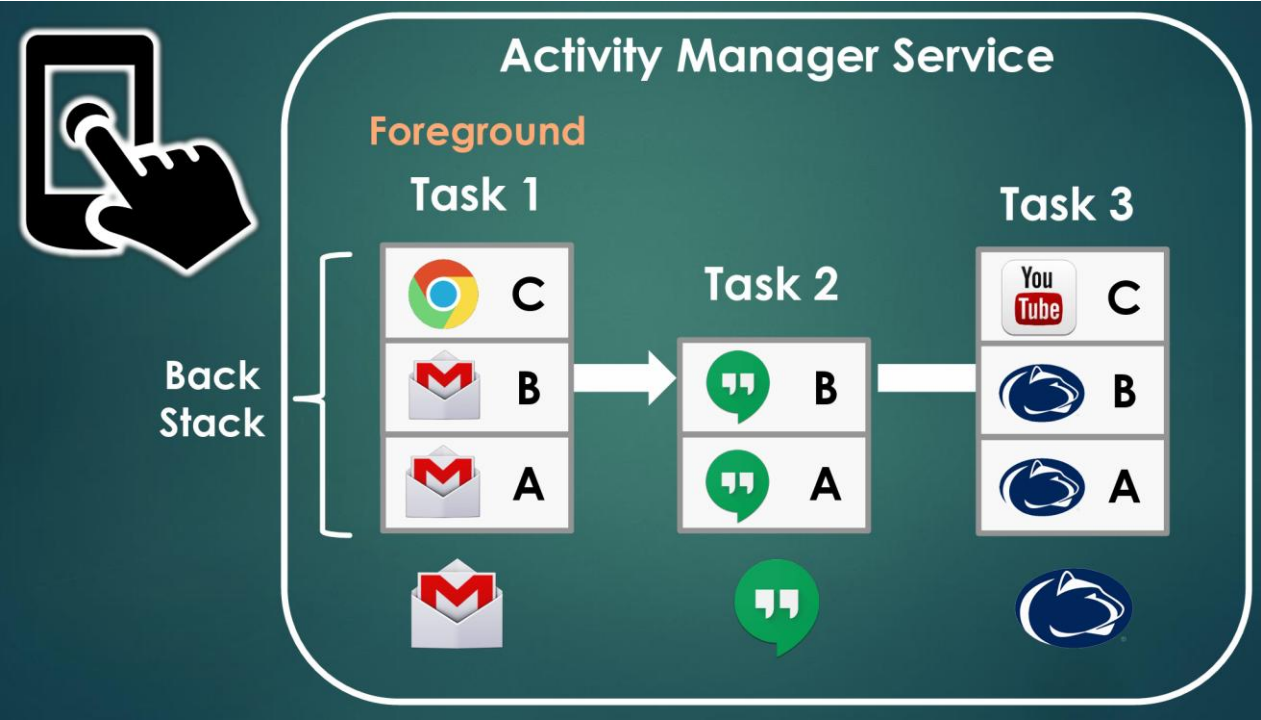
“A task is a collection of activities that users interact with when performing a certain job”

-Android developer documentation



点击劫持示例

Android Multi-tasking



Lifecycle of Android Task



点击劫持示例



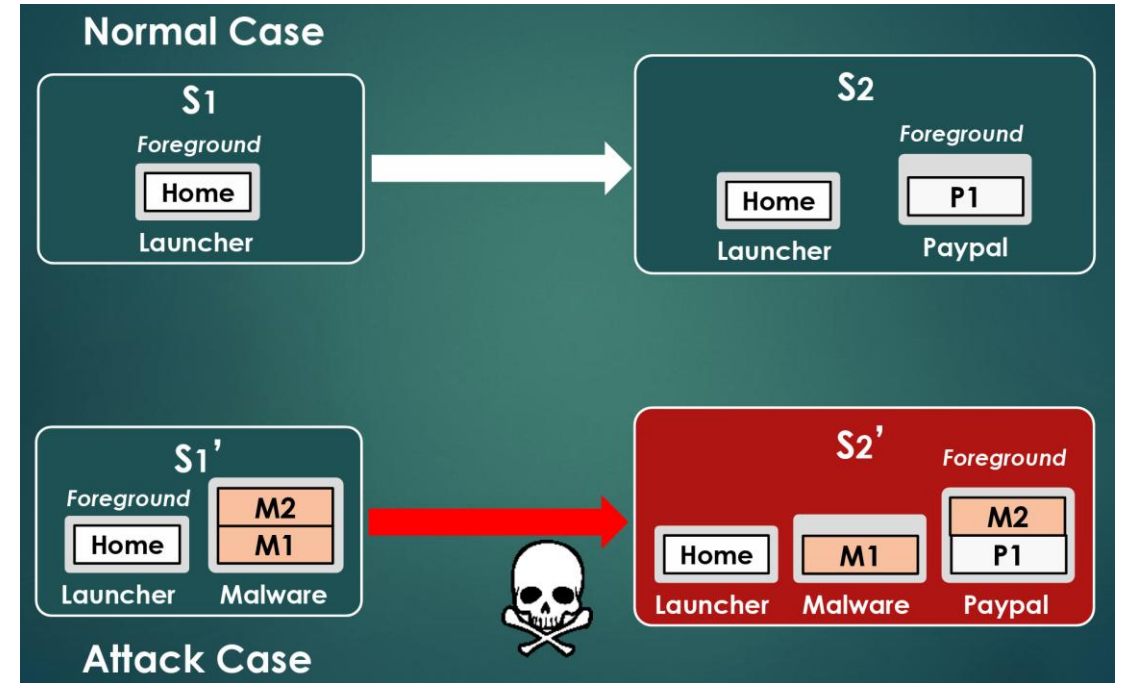
Security Concerns

- ❑ However, the security implication of Android multitasking remains under-investigated
 - Android allows activities from different apps to reside in the same task (or back stack):
 - Android offers developers great flexibility to customize task behaviors
- ❑ We find that Android multitasking is plagued by a serious security risk-**task hijacking**

点击劫持示例



Example – User Spoofing



How does mal-activity migrate?

- ❑ The malware tricks the system to relocate the malicious activity (M2) to the PayPal task by manipulating the following task control knobs:
 - Task affinity
 - `allowTaskReparenting`

点击劫持示例

Task Affinity

- ❑ An activity attribute defined in each `<activity>` tag in `AndroidManifest.xml`
- ❑ Task affinity specifies which task that the activity desires to join. By default, all activities in an app have the same affinity-the app package name

```
<manifest xmlns:android="http://schemas.android.com/apk/res/android"
    package="com.example.app" >

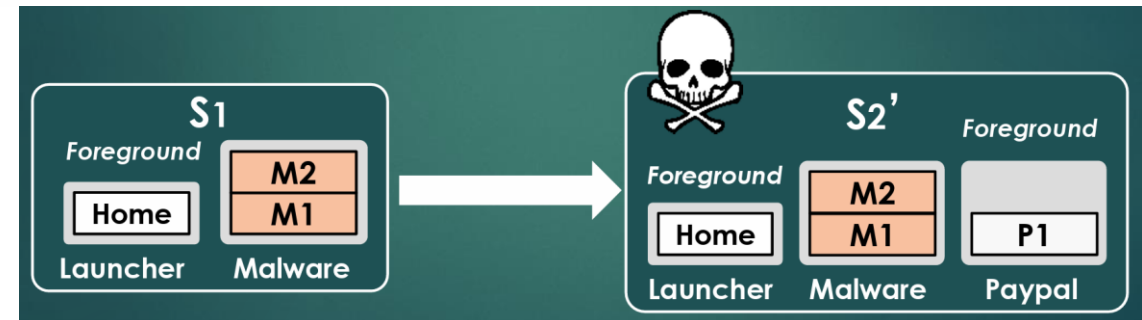
    <application>
        <activity android:name=".ActivityA" />
        <activity android:name=".ActivityB" android:taskAffinity="com.example.app:taskB" />
    </application>
</manifest>
```

- ❑ Developer can re-define the task affinity in order to achieve desirable task behavior
 - Group activities into different tasks
 - Place activities defined in different apps within the same task
- ❑ If `<allowTaskReparenting = "true">` for activity A, and when a task with the same affinity as A is brought to the front, the system would move the “relocatable” activity A from its original hosting task to this new foreground task

User Spoofing Attack

Malware abuses the following task control knobs:

1. Activity M2:taskAffinity= com.paypal.android
2. Activity M2:allowTaskReparenting = true



点击劫持示例

Research Questions

Question 1: How many types of task hijacking?

Question 2: How to craft the individual attacks?

Question 3: How to assess the vulnerability?

Question 4: How to defend task hijacking?

Task Control Knobs

We find that there are a rich set of task control knobs that can be abused by a task hijacking attack

Task control knobs in 4 categories:

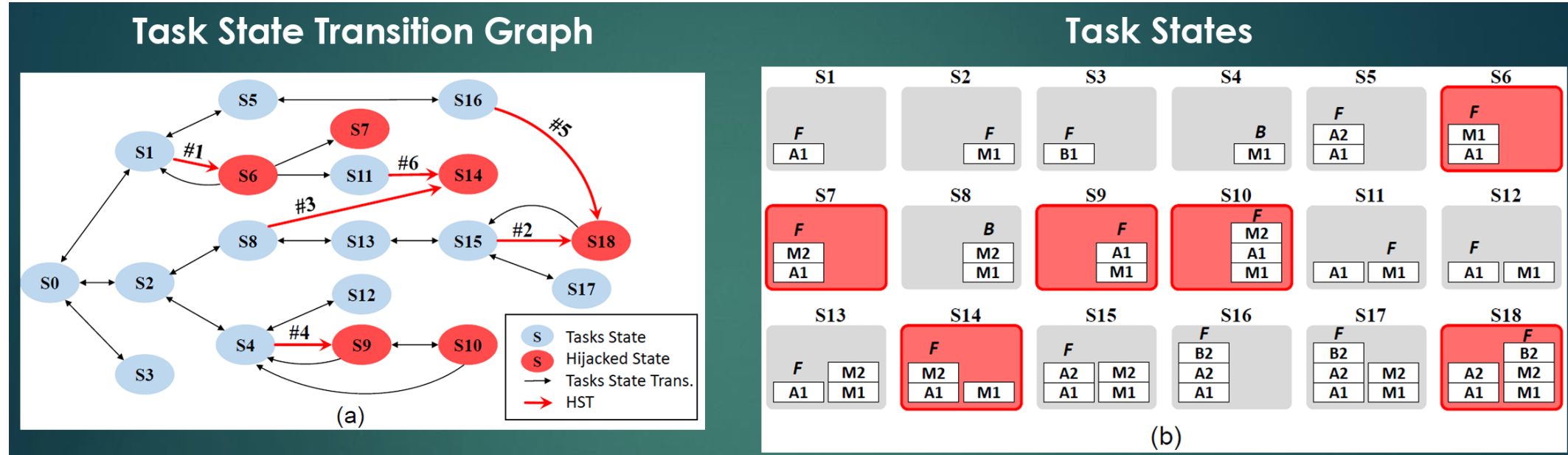
Intent Flag	Activity Attribute	Call-back Function	Framework API
NEW_TASK SINGLE_TOP REORDER_TO_FRONT NO_HISTORY CLEAR_TASK NEW_DOCUMENT MULTIPLE_TASKS	launchMode taskAffinity allowTaskReparenting documentLaunchMode FinishOnTaskLaunch	onBackPressed()	TaskStackBuilder class startActivity() startActivities()

Methodology

- ❑ We formalize the task dynamic as a state transition model
 - Hijacked task state: at least one task in the system contains both malicious and benign activities
 - Hijack state transition (HST): state transition that leads the system to a hijacked task state
- ❑ We simulate an Android system with three apps
 - Two benign apps (A, B), one malware (M)
 - Connect task states and generate task state transition graph
 - Flag the hijacked task states and HST in the graph

点击劫持示例

Question 1: Types of Task Hijacking



Two types of Hijacking State Transitions (HST):

- Malware activity moves to benign app task
- Benign activity is placed into malware task

Observations:

- There are many possible hijacking state transitions (HSTs)
- Once exploited, the HSTs could result in practical and serious real-world attacks

点击劫持示例

Question 2: Enabled Attacks

We implemented 6 proof-of-concept attacks in 3 categories.

Attack Category	Consequence	Attack Name	Vulnerable Systems & Apps
User Spoofing	Sensitive information stolen	Spoofing attack	all ; all
		Phishing attack (I – III)	all ; some apps
Denial-of-service	App function disabled; Restriction of user access	Ransomware	>Android 5.0 ; all
User Monitoring	User privacy infringement	Spyware	>Android 5.0 ; all

Task hijacking attacks affect all latest Android versions and apps, including the most privileged apps!

Question 3: Vulnerability Assessment

- ❑ We would like to first understand the use of security-sensitive task control knobs in real implementation
- ❑ We analyze 6.8 million apps from Google Play and other 12 popular third-party app markets

Activity Attribute	% of Apps	Intent Flag	% of Apps
allowTaskReparenting="true"	0.80	NEW_TASK	79.42
launchMode="singleTask"	24.63	CLEAR_TOP	37.59
launchMode= other non-default modes	24.75	EXCLUDE_FROM_RECENTS	10.08
taskAffinity= own pck. name	2.36	Events	
taskAffinity= other	1.60		
excludeFromRecents="true"	12.45		
alwaysRetainTaskState="true"	2.03		
		onBackPressed()	62.00
		TaskStackBuilder	7.27
		startActivities()	5.47

点击劫持示例

Case Study-Task Affinity

- ❑ 1.6% (109K apps) of all apps set the task affinity without containing their own package name
- ❑ These apps may interfere with the multitasking behaviors of other apps
 - Unintentional: careless app developers who are unaware of the security implications.
 - Intentional: task affinity intentionally set to popular app's package name in order to implement legitimate “add-on” feature for these popular apps.
 - We have not found evidence that malware has already abused these task control knobs

Question 4: Defense Suggestions

- ❑ Detection in app review process
 - App review guideline may contradict with existing app features
 - Challenging to detect stealthy dynamic behaviors of an advanced malware
- ❑ More secure multi-tasking mechanism
 - Introduce additional security features for multitasking contro!
 - For example, task affinity should comply with certain name space specification
 - Introduce additional Boolean attribute to control if the app allow other apps to specify the same task affinity

点击劫持示例

Proof-of-concept Attack Demo

❑ Phishing attack

- A malware can steal user Citi Bank account name and password by hijacking citi bank task with a spoofing Citibank login interface

❑ Denial of service

- A malware can disable app uninstallation in a system
- The similar attack approach could be used to create a ransomware

传播-社会工程学-垃圾电子邮件、木马

社会工程学

垃圾邮件

垃圾电子邮件

恶意软件的
重要载体

被用作钓鱼攻击

特洛伊木马

内部藏有恶意代码，
当被调用时，会执行
非预期的或有害的
功能

特洛伊木马程序可以
间接完成一些未授权
用户无法直接完成的
功能

手机木马

首次在2004年发现
(Skuller)

目标是智能手机

传播-社会工程学-垃圾电子邮件、木马

激活恶意软件

□ Once malware is installed it will listen to events to start its malicious activity

-BOOT_COMPLETE and SMS_RECEIVED are the most common

□ Hijacking events to substitute the legitimate app activity with the malicious one

-ACTION_MAIN or the user click the app icon

载荷-系统损坏



Chernobyl 病毒

- 首次发现于1998年
- 是一个有破坏性的、寄生性的、内存驻留性质的病毒，运行于Win95和98系统上
- 它会在可执行文件被打开时感染它们。当触发日期一到，它会用0覆盖硬盘的第一个兆字节的数据以删除被感染系统中的数据，导致整个文件系统的大面积损坏

求职信（Klez）蠕虫

- 它感染从 Windows 95到Windows XP的一系列操作系统
- 首次发现于2001年10月
- 求职信蠕虫通过电子邮件，向用户地址簿中的邮箱地址和系统中的文件传播自身的拷贝
- 它可以暂停和删除一些运行在系统中的反病毒程序
- 在发作日期，即每年某几个月的13号，它会清空本地硬盘下的文件

勒索软件 (Ransomware)

- 恶意软件会加密用户数据，然后向用户索要赎金才可以恢复数据
- 1989年发现的Cyborg 木马就是早期的例子
- 到了2006年年中，涌现出一批使用公钥加密算法和越来越长的密钥对数据进行加密的蠕虫和木马(如 Gpcode木马)
- 用户必须支付赎金，或在指定网站进行支付才可以拿到解密的密钥

载荷-系统损坏

WannaCry

- 在2017年5月感染了许多国家的很多系统
- 当其被安装在被感染的系统上，它会加密大量满足列表中文件类型要求的文件，而后索要比特币赎金来恢复它们
- 一旦这种情况发生，信息的恢复只能依赖于组织有良好的备份、应急响应措施、灾难恢复计划
- 攻击目标已经超出个人计算机系统，包括移动设备和Linux服务器
- 而威胁公布敏感个人信息或在短时间内永久销毁加密密钥等策略有时被用来增加受害者付费的压力

载荷-系统损坏

物理损害和逻辑炸弹

- 物理设备的损害
 - 引起物理设备的损害
 - Chernobyl病毒不仅毁坏数据，还会试图重写用于引导计算机启动的BIOS代码
 - Stuxnet 蠕虫
 - 有效载荷以一些特殊工业控制系统为目标
 - 震网蠕虫提高了对使用复杂和有针对性的恶意软件产生的工业设备破坏问题的关注
- 逻辑炸弹
 - 嵌入在恶意软件中的代码，在特定条件满足时便会“爆炸”

载荷-攻击代理-zombie、bot

bot

- 会秘密控制一台连接Internet 的计算机，并利用所控制计算机发动攻击
- Botnet – 一大群僵尸机组成了僵尸网络，以一种协调的方式运行
- 集合
 - 分布式拒绝服务攻击 (DDoS)
 - 发送垃圾邮件
 - 嗅探通信流量
 - 记录键盘
 - 传播新的恶意软件
 - 安装广告插件和浏览器辅助插件
 - 攻击IRC聊天网络
 - 操纵在线投票或游戏

载荷-攻击代理-zombie、bot

远程控制功能

- Bot和蠕虫的区别
 - 蠕虫自我繁殖并激活自己
 - Bot是由某种形式的指挥控制服务器网络控制的
- 早期实现远程控制的工具是IRC服务器
 - 所有bot都会加入这个服务器的一个特定通道中，并把通道中收到的消息当作命令处理
 - 越来越多的僵尸网已经避免使用IRC机制了，转而利用协议(如HTTP协议)来实现隐蔽通信通道
 - 利用点对点通信协议的分布式控制机制也是一种可用的控制方法，以避免单一控制节点容易失效的不足

载荷-信息窃取-键盘记录器、网络钓鱼、间谍软件

键盘记录器和间谍软件

- 键盘记录器
 - 抓取被感染机器中的键击信息，从而攻击者可以监视那些敏感信息
 - 一般都会设置一些过滤机制以便只记录与攻击者想要的关键字相近的信息（如“登录名”“口令”或“paypal.com”）
- 间谍软件
 - 用以监听受害系统中更多种类的活动
 - 监视历史记录和浏览内容
 - 更改某一网页至攻击者控制的虚假网站
 - 动态修改浏览器和网站交换数据，导致用户私人信息遭到严重的侵害

载荷-信息窃取-键盘记录器、网络钓鱼、间谍软件

网络钓鱼和身份盗窃

- 利用社会工程，通过伪装成可信来源的通信来取得用户的信任
 - 在垃圾邮件中包含指向被攻击者控制的虚假网站URL，并让这个虚假网站模仿一些银行、游戏或其他类似网站的登录界面
 - 此类邮件通常包含有提示用户需要紧急验证他们的账户以免被锁定的消息
 - 如果用户不加小心，没有发现自己正受到诈骗，跟随链接并提供了需要的细节信息，就无疑会导致攻击者利用截获的凭证信息攻陷用户的账户
- 鱼叉式网络钓鱼
 - 邮件的收件人事先已经受到了攻击者的认真研究
 - 因为每封邮件都是精心制作的以迎合相应的收件人(通常是通过引用一系列信息以说服收件人相信邮件的可靠性)

载荷-隐蔽-后门、rootkit

后门

- 后门也称为陷门
- 指的是一个程序的秘密入口，使得知情者不经过通常的安全访问程序而获取访问权限
- 维护挂钩指的是程序员开发者合理用于程序的调试和测试的后门
- 很难通过操作系统对后门进行控制

载荷-隐蔽-后门、rootkit

rootkit分类特征

持续的

基于
内存的

用户模式

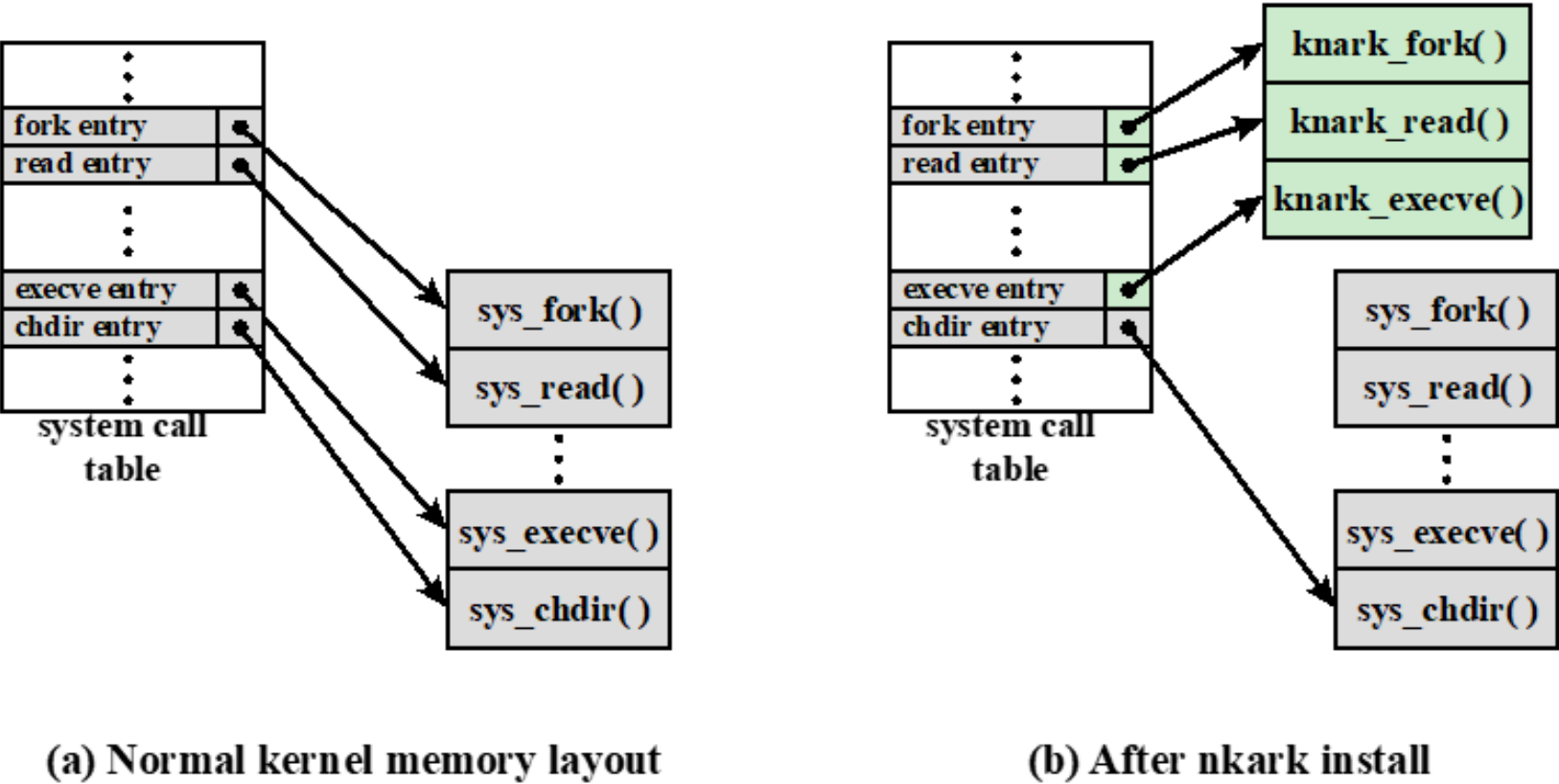
内核模式

基于
虚拟机的

外部模式

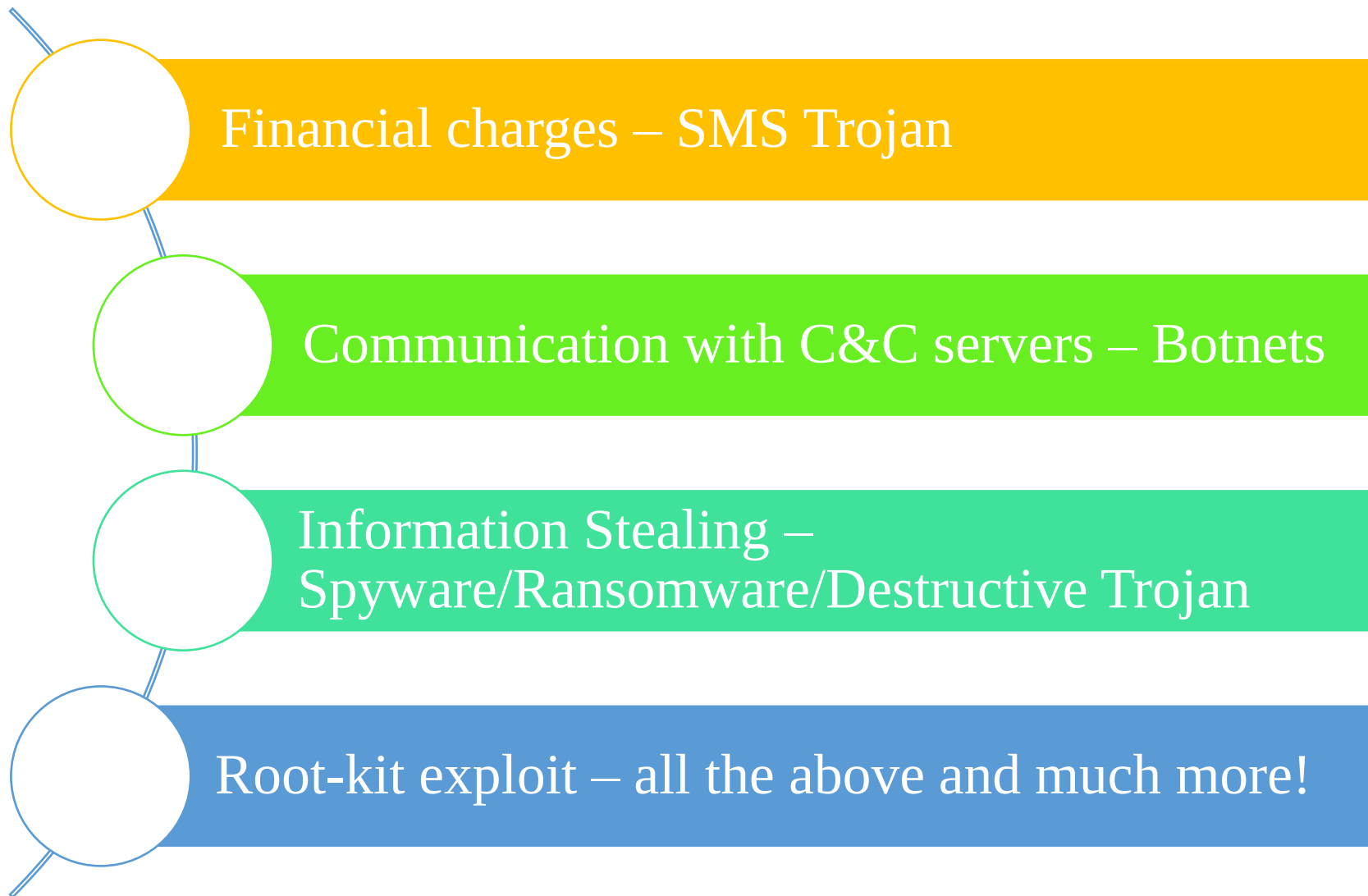
载荷-隐蔽-后门、rootkit

内核模式下的rootkit



载荷-隐蔽-后门、rootkit

攻击类型



对抗手段

针对恶意软件的对抗措施

- 对抗恶意软件威胁的理想解决方案是预防，预防的四个主要要素是：

规则

警惕性

弥补弱点

缓解威胁

- 如果预防失败，技术机制可用于支持以下减少威胁的备选办法：

检测

识别

清除

对抗手段

杀毒软件的演变

第一代:简单的扫描器

- 需要病毒特征码来识别病毒
- 仅限于检测已知的恶意软件

第二代:启发式扫描器

- 通过启发式规则来检测可能存在的病毒感染
- 另一种方法是完整性检查

第三代:活动陷阱

- 第三代反病毒程序是内存驻留程序,它通过病毒行为来识别病毒,而不是通过被感染文件的内部结构特征

第四代:全面的保护

- 综合运用各种反病毒技术的软件包
- 包括扫描和活动陷阱组件,同时还加入了访问控制功能

对抗手段

沙箱分析

- 在沙箱或虚拟机中运行恶意代码
- 这可以保证代码在可控制的环境内运行，其行为可以被近距离监控，同时不会对实际的系统安全造成威胁
- 在这种环境中运行潜在的恶意软件可以让检测系统对恶意软件复杂加密、多态或变质进行检测
- 沙箱分析设计最困难的部分是确定执行每次解释所需的时间

对抗手段

基于主机的动态恶意软件分析

- 动态恶意软件分析或行为阻断软件与主机的操作系统相结合，实时监控恶意的程序行为
 - 行为阻断软件能够在程序的恶意行为影响计算机之前将其阻断
 - 因为动态分析软件能及时阻断可疑软件的执行，这比起现有的反病毒检测技术(如特征码技术和启发式技术)具有很大的优势
- 限制
 - 因为在恶意程序的所有行为被识别出来之前，该程序已经在目标机器上执行了，所以在它被检测并阻止之前就可能已经对系统造成了损害

对抗手段

边界扫描处理

- 通常包含在运行于这些系统上的电子邮件和 Web代理服务中
- 但也可能包含在入侵检测系统的流量分析组件中
- 反病毒软件也可能包含有预防入侵的措施，有能力屏蔽任何可疑的网络流量
- 方法存在局限性，只能扫描恶意软件内容

对抗手段

边界扫描处理

入口监控软件

- 这类软件被安装在企业内部网络和Internet之间
- 它们可以是一个边界路由器或者外部防火墙或者独立的被动监控器的入口过滤软件的一部分

出口监控软件

- 这些软件可以被安装在企业内部网络中的各个独立局域网的出口点上，也可以被安装在企业内部网与Internet之间
- 通过监控输出通信中是否存在扫描或者其他可疑行为来捕获恶意软件攻击的源头

本章小结

- 6.1 恶意软件的类型
 - 6.1.1 恶意软件的粗略分类
 - 6.1.2 攻击工具包
 - 6.1.3 攻击源
- 6.2 高级持续性威胁
- 6.3 传播-感染内容-病毒
- 6.4 传播-漏洞利用-蠕虫
 - 6.4.1 发现目标
 - 6.4.2 蠕虫传播类型
 - 6.4.3 Morris 蠕虫
 - 6.4.4 蠕虫攻击简史
 - 6.4.5 蠕虫技术的现状
 - 6.4.6 移动代码
 - 6.4.7 手机蠕虫
 - 6.4.8 客户端漏洞和路过式下载
 - 6.5.8 点击劫持
- 6.9 载荷-隐藏-后门、rootkits
 - 6.9.1 后门
 - 6.9.2 Rootkit
 - 6.9.3 内核模式下的rootkit
 - 6.9.4 虚拟机和其他外部rootkit
- 6.5 传播-社会工程-垃圾电子邮件、木马
 - 6.5.1 电子邮件
 - 6.5.2 特洛伊木马
 - 6.5.3 手机木马
- 6.6 载荷-系统损坏
 - 6.6.1 数据损坏和勒索软件
 - 6.6.2 物理损害
 - 6.6.3 逻辑炸弹
- 6.7 载荷-代理攻击-zombie, bots
 - 6.7.1 Bot的用途
 - 6.7.2 远程控制功能
- 6.8 载荷-信息窃取-键盘记录器、网络钓鱼、间谍软件
 - 6.8.1 凭证盗窃、键盘记录器和间谍软件
 - 6.8.2 网络钓鱼和身份盗窃
 - 6.8.3 侦查、间谍和数据渗透
- 6.10 对抗手段
 - 6.10.1 针对恶意软件的对抗措施
 - 6.10.2 基于主机的扫描器和基于签名的反病毒软件
 - 6.10.3 边界扫描处理
 - 6.10.4 分布式情报搜集处理